

OWASP Top 10 (2025) - Study Checklist

A learning checklist covering what to know under each 2025 category - for VAPT / penetration testing prep.

#	2025 Category	2021 Position / Change
01	Broken Access Control	Same (#1) - now absorbs SSRF
02	Security Misconfiguration	Up from #5
03	Software Supply Chain Failures	NEW (expands old Vulnerable Components)
04	Cryptographic Failures	Down from #2
05	Injection	Down from #3
06	Insecure Design	Same (#4 -> #6 slot, concept unchanged)
07	Authentication Failures	Renamed, same rank area
08	Software or Data Integrity Failures	Same (#8)
09	Security Logging and Alerting Failures	Renamed (was ...Monitoring...)
10	Mishandling of Exceptional Conditions	NEW - replaces standalone SSRF

A01:2025 - Broken Access Control

Still the #1 risk. Now absorbs SSRF as well as CSRF.

- IDOR (Insecure Direct Object Reference) via changed IDs/params
- BOLA / BFLA (Broken Object/Function Level Authorization - API specific)
- Missing function-level access control (admin routes reachable by normal users)
- Privilege escalation - horizontal and vertical
- CORS misconfiguration allowing unauthorized origins
- CSRF - missing or predictable anti-CSRF tokens
- JWT tampering / signature not verified server-side
- Force-browsing to authenticated/protected pages
- Directory listing or unprotected directories exposing files
- SSRF - unvalidated server-side requests to internal services or cloud metadata endpoints (169.254.169.254)

A02:2025 - Security Misconfiguration

Jumped from #5 (2021) to #2 (2025).

- Default credentials left unchanged
- Verbose error messages / stack traces exposed to users
- Unnecessary features, ports, or services left enabled
- Missing security headers (CSP, HSTS, X-Frame-Options)
- Debug mode enabled in production
- Cloud/storage misconfiguration (open S3 buckets, exposed consoles)
- Outdated software/framework configs left at insecure defaults
- Unpublished/hidden URLs not properly access-restricted
- Poor application coding practices exposing internal structure
- Directory traversal due to weak path handling

A03:2025 - Software Supply Chain Failures

NEW category - expands the old "Vulnerable and Outdated Components".

- Compromised or malicious third-party packages
- No SBOM (Software Bill of Materials) or dependency inventory
- Insecure CI/CD pipeline (weak access control, no review gates)
- Unsigned or unverified build artifacts
- Compromised container registries or build infrastructure
- Dependencies pulled from untrusted/unvetted repositories
- No monitoring for newly disclosed CVEs in used components

A04:2025 - Cryptographic Failures

Dropped from #2 (2021) to #4 (2025).

- Sensitive data transmitted in cleartext (no TLS/HTTPS)
- Weak or deprecated algorithms (MD5, SHA1, DES)
- Hardcoded encryption keys/secrets in source code

- Passwords used directly as cryptographic keys
- Insufficient randomness - predictable tokens/session IDs
- Improper certificate validation
- Missing encryption at rest for PII, cards, passwords
- Deprecated TLS versions still supported (SSLv3, TLS 1.0/1.1)

A05:2025 - Injection

Dropped from #3 (2021) to #5 (2025). Includes XSS.

- SQL Injection
- NoSQL Injection
- OS command injection
- XSS - stored, reflected, and DOM-based
- LDAP injection
- XPath injection
- Template injection (SSTI)
- Missing input validation / no parameterized queries

A06:2025 - Insecure Design

Same position as 2021 - flaws in architecture, not just implementation.

- No threat modeling performed during design phase
- No security requirements defined upfront
- Business logic flaws (negative quantities, price tampering)
- Missing rate limiting by design
- Trust boundaries not clearly defined
- Insecure workflows (e.g. password-reset logic flaws)

A07:2025 - Authentication Failures

Renamed from 'Identification and Authentication Failures'.

- Weak password policy (no complexity/length rules)
- No account lockout / brute-force protection
- Session ID exposed in URL
- Session fixation
- Missing multi-factor authentication (MFA)
- Weak 'forgot password' / account recovery mechanisms
- No credential-stuffing mitigation
- Session timeout not implemented

A08:2025 - Software or Data Integrity Failures

Same position as 2021. Distinct from A03 - this is runtime/delivery integrity.

- Unsigned or unverified software updates (no integrity checks)
- Insecure CI/CD pipeline access (overlaps with A03, different angle)

- Auto-update mechanisms without source verification
- Insecure deserialization leading to RCE
- Untrusted plugins/libraries loaded from unverified sources
- No code/config review process before deployment

A09:2025 - Security Logging and Alerting Failures

Renamed from "Security Logging and Monitoring Failures" - emphasizes alerting.

- No logging of login attempts or access-control failures
- Logs exist but are not actively monitored or alerted on
- Logs stored insecurely (tamperable, not write-protected)
- No audit trail for sensitive actions
- Insufficient log detail (missing timestamp, user ID, IP)
- No incident response plan tied to logging/alerting data

A10:2025 - Mishandling of Exceptional Conditions

Brand NEW category - replaces the standalone SSRF slot from 2021.

- Errors/exceptions not caught, causing crashes or undefined states
- Fail-open behavior instead of fail-closed on error
- Edge cases / boundary conditions not handled, enabling logic bypass
- Inconsistent error handling across services leaking internal state
- Unhandled exceptions leaking stack traces or sensitive data